

Vendor & Subprocessor Management Policy

Version: v1.0 ADOPTED **Adopted:** 2026-07-21 by Sami Ben Chaalia (Security Officer) **Date:** 2026-07-21 **Owner:** Security Officer (Sami Ben Chaalia) **Framework mapping:** SOC 2 CC9.2 (Vendor Risk) · HIPAA §164.308(b) Business Associate Contracts + §164.502(e)(1)(ii) Subcontractors · GDPR Art. 28 processor contracts **Companion documents:** BAA_DRAFT.md Exhibit C (subprocessors), Encryption Policy §8, Incident Response Policy §7.4–7.7.

1. Purpose

Enumerate every third party that touches RailCall infrastructure or customer-adjacent data, WHY they touch it, what they can see, and what happens if they fail. Keep the list honest and current — an incomplete subprocessor disclosure is itself a breach of §164.502(e)(1)(ii).

2. Scope

Every third party in the RailCall operational path. Ranked by the sensitivity of what they see.

Out of scope: dev-time tooling that never sees a byte of customer or operator secret (test frameworks, editor plugins, etc.).

3. Current vendor inventory

Sorted by criticality. Each row is a live decision — if we can't defend the entry today, we shouldn't be using the vendor today.

3.1 Render — gateway hosting

- **What they touch:** the `railcall-core` FastAPI service (all paid-tier code paths), managed Postgres holding `consumers` + `seat_reservations` + `processed_events`, service logs, `RAILCALL_ISSUER_SEED` and `STRIPE_SECRET_KEY` as env vars.
- **Why them:** operational simplicity for a two-person team — managed Postgres, TLS termination, deploy-on-push. Alternative considered: DigitalOcean App Platform, AWS Fargate + RDS. Render chosen for lower ops overhead at our scale.
- **Their posture:** SOC 2 Type II (published), GDPR/CCPA-ready per their DPA, US + EU regions available. Encryption at rest on managed Postgres, TLS 1.3 in transit.
- **What they see about customers:** email addresses at signup, `sha256(api_key)` on every request, install pubkeys on seat checkin. Never raw api_keys after minting, never workflow

data, never PHI (see Encryption Policy §5).

- **What they see about us:** every gateway secret (`RAILCALL_ISSUER_SEED` in particular). This is a hard trust boundary — a Render employee with production DB access could theoretically read the seed. Mitigation: none technical; contract + Render's own SOC 2 controls.
- **Replaceability:** medium. Migrating gateway = redeploying FastAPI on another platform + rewiring env vars + swapping Stripe webhook target. Estimated 1–2 days of work; DNS TTL is the customer-facing risk (short-lived pointer to gateway URL).
- **Review cadence:** on every Render pricing/policy change email; at least annually.

3.2 Stripe — payments + subscription lifecycle

- **What they touch:** every \$, every card, every subscription. Sends `checkout.session.completed`, `customer.subscription.deleted`, etc., to our webhook.
- **Why them:** PCI-DSS Level 1 out of the box, the ubiquitous choice for a US-based SaaS. Alternative considered: Paddle (better VAT handling), Lemon Squeezy. Stripe chosen for API depth + Anthropic-tier reliability.
- **Their posture:** SOC 1/2 Type II, PCI-DSS Level 1, GDPR-compliant DPA.
- **What they see about customers:** everything — name, billing address, card number, purchase intent. RailCall NEVER sees the card number — it only sees a `customer_email`, `customer_id`, and payment status.
- **What they see about us:** live secret keys, webhook signing secret, per-price product configuration.
- **Replaceability:** low. Migrating Stripe = re-onboarding every paying customer (new payment method, new subscription). Would be a business-continuity event.
- **Review cadence:** quarterly review of restricted-key inventory (revoke stale ones); annually on the vendor itself.

3.3 Anthropic — LLM for Probo (dev-only tooling)

- **What they touch:** any prompt Probo's internal agents send (probo agent, evidence describer, third-party vetter, tracker mapping). Probo runs on Sami's laptop — a customer does NOT reach Anthropic through RailCall.
- **Why them:** Claude models power the compliance-drafting loop that made these very policies possible. Alternative: OpenAI (same LLM class). Both providers wired in `PROBOD_AGENT_DEFAULT_PROVIDER`; either can be swapped by env var.
- **Their posture:** SOC 2 Type II, HIPAA-eligible with signed BAA (not signed by RailCall for Probo use because no PHI reaches this path).
- **What they see about customers:** nothing. Probo is fed our own SRA, our own control descriptions, our own policy drafts. Customer data does not leave our infrastructure to reach

Anthropic.

- **What they see about us:** the internal state of our compliance program (policies in draft, control implementation notes). Sensitive but not customer-sensitive.
- **Replaceability:** high. Swap `PROBOD_AGENT_DEFAULT_PROVIDER=openai` and set `PROBOD_OPENAI_API_KEY`; no data-model migration needed.
- **Review cadence:** annually; sooner if Anthropic changes its retention policy.

3.4 GitHub (patl4588 organisation) — source + release hosting

- **What they touch:** every line of source code, every release tarball (station-v0.16 and predecessors), every install script mirror, this policy folder.
- **Why them:** default in the ecosystem, developer tools + CI + release hosting all in one. Alternative: GitLab, self-hosted Gitea. GitHub chosen for ecosystem inertia.
- **Their posture:** SOC 2 Type II (Microsoft), extensive breach transparency, MFA + SSO available.
- **What they see about customers:** nothing. Source is not customer data.
- **What they see about us:** every RailCall secret we accidentally commit — mitigated by pre-push review + `install.sh` -level leak gate in the release script that refuses tarballs containing moat artifacts. No `.env` files, no seed material, no vault files are ever committed (verified by `.gitignore` + the leak gate).
- **Replaceability:** medium. Git itself is portable; the ecosystem (Actions, PR flow, gh CLI) is where lock-in lives.
- **Review cadence:** annually; sooner on any GitHub security incident affecting orgs we're part of.

3.5 DigitalOcean VPS 157.230.177.45 — railcall.ai website + installer mirror

- **What they touch:** the Next.js site (`railcall-contrib/website-v2` deployed via pm2), the installer + station tarball mirror, static compliance / legal pages.
- **Why them:** cheap VPS with predictable pricing + snapshot backups. Alternative: Vercel/Netlify for the Next.js side. VPS chosen for full control over the installer mirror (matters for the release ceremony's byte-compare property).
- **Their posture:** SOC 2 (published), ISO 27001, weekly snapshots retained 4 weeks.
- **What they see about customers:** signup emails from the marketing site's contact forms (if any). No paying-customer data goes through the VPS.
- **What they see about us:** the SSH key giving Sami operator access, all static files on disk.
- **Replaceability:** high. Static-site deploy anywhere; installer mirror can move to any HTTP host that supports SNI + reasonable TLS.
- **Review cadence:** annually; on any DO security advisory.

3.6 Cloudflare — DNS + edge for railcall.ai

- **What they touch:** DNS resolution for `railcall.ai`; TLS termination in front of the VPS if that's how it's currently wired (verify against DNS records at review time).
- **Why them:** free/cheap tier, robust DNS, DDoS mitigation.
- **Their posture:** SOC 2, ISO 27001, extensive compliance surface. Notable: DNS logs may include client IPs — treat as processor data under GDPR for EU visitors.
- **Replaceability:** trivial for DNS; higher if we rely on any Cloudflare-specific feature (Workers, R2). Currently: DNS + edge cache only, so trivial.
- **Review cadence:** annually.

3.7 1Password — Sami's secret storage

- **What they touch:** every RailCall root secret Sami holds — issuer seed, deploy SSH keys, Stripe standard-key backups, personal credentials.
- **Why them:** Sami's existing password manager; already used for personal + operator secrets.
- **Their posture:** SOC 2 Type II, end-to-end encrypted with a master passphrase Sami never shares.
- **What they see about customers:** nothing. Customer data is not in 1Password.
- **What they see about us:** everything, encrypted such that a 1Password insider cannot read without Sami's master passphrase.
- **Replaceability:** high. Exports to standard formats; another password manager or offline paper storage is a swap.

4. Onboarding a new vendor

Any addition to §3 requires the following BEFORE production traffic reaches them:

1. **Purpose statement.** One sentence: what data class does this vendor touch, and why is that the smallest amount that works?
2. **Compliance posture check.** SOC 2 / ISO 27001 / HIPAA-eligibility as applicable. If they don't have a relevant certification and they touch customer-sensitive data, they don't get added.
3. **DPA / BAA signed** if they process personal data or PHI. For a US vendor: their standard DPA is usually fine; for EU personal data, verify Standard Contractual Clauses are in place.
4. **Update this policy AND `BAA_DRAFT.md` Exhibit C.** Missing a subprocessor from the BAA disclosure is a §164.502(e)(1)(ii) breach — the disclosure itself is the compliance object.
5. **Notify affected customers.** Any customer with an active BAA gets 30-day written notice via `security@railcall.ai` before the new subprocessor goes live for their data (per BAA §2.5 in

the current draft).

5. Offboarding a vendor

1. **Cut off access first.** Rotate credentials, remove SSH keys, revoke API tokens.
2. **Extract our data.** Downloads, exports, or DB dumps from every vendor-hosted store.
3. **Confirm deletion at the vendor.** Every SOC 2 vendor supports "delete my data" — hold them to it in writing.
4. **Remove from this policy AND from `BAA_DRAFT.md` Exhibit C.**
5. **Retain a decision record.** Why we left, when, what data was migrated where.

6. Vendor incidents

Cross-reference `Incident Response Policy` §7.4–7.7 for the per-vendor runbook. Notification obligation applies both ways: - **They notify us:** track it via their status page + any direct email; treat as our own incident from the moment we're aware. - **We notify them:** if a RailCall incident affects data they process (e.g., our webhook secret leaks), tell Stripe / Render / whoever is affected. Ask them to confirm no downstream impact.

7. Review cadence

- **Per-vendor:** as listed in §3 (mostly annual).
- **Whole policy:** annually + on any material change to a vendor (pricing tier change, ownership change, compliance certification lapse).
- **Customer-facing subprocessor list** (railcall.ai/legal/subprocessors — TO BE CREATED): updated within 30 days of any §3 change, per common DPA obligations.

8. Related documents

- **BAA_DRAFT.md** Exhibit C — the customer-facing legal disclosure of these subprocessors. This policy is the operator-facing detail; Exhibit C is the customer-facing summary.
- **Encryption Policy** §8 — what encryption we entrust to each of them.
- **Incident Response Policy** §7.4–7.7 — how we respond when each of them fails.
- **Access Control Policy** §6 — who on our side has access to each vendor's console.